

Skill Arena - Phase 4 Document 2

API Security, Service Security, Infrastructure Security & Network Protection Architecture

Document Purpose

Define how APIs, backend services, servers, networks and cloud infrastructure are protected against unauthorized access and attacks.

Business Objective

Ensure platform availability, confidentiality, integrity and resilience under normal and hostile conditions.

Security Philosophy

All services operate under Zero Trust principles. Every request is authenticated, authorized and monitored.

API Security Architecture

Central API Gateway, Authentication Layer, Authorization Layer, Rate Limiting Engine and Audit Layer.

API Authentication

JWT validation, service authentication, token verification and request signing.

API Authorization

Role-based and permission-based access control for every endpoint.

Rate Limiting

Prevent abuse, scraping, brute-force attacks and denial-of-service attempts.

Input Validation

Strict validation, sanitization and schema enforcement for all incoming requests.

Service Security

Microservices communicate through authenticated and encrypted channels.

Service Isolation

Critical services separated into protected trust zones.

Secrets Management

Centralized secure storage of API keys, credentials, certificates and encryption keys.

Infrastructure Architecture

Public Zone, Application Zone, Service Zone, Data Zone and Security Zone.

Network Segmentation

Internal systems isolated from public-facing services.

Firewall Strategy

Layered firewall rules protecting APIs, services and databases.

DDoS Protection

Traffic filtering, rate controls, edge protection and automated mitigation.

Cloud Security

Secure cloud configuration, hardened workloads and continuous posture monitoring.

Database Protection

Private network access, encryption and restricted administrative access.

Encryption Standards

TLS for data in transit and strong encryption for data at rest.

Monitoring Framework

Infrastructure monitoring, API monitoring, service monitoring and network monitoring.

Threat Detection

Detection of intrusion attempts, abnormal traffic and suspicious service activity.

Vulnerability Management

Continuous scanning, patch management and remediation workflows.

Penetration Testing

Regular security testing of APIs, infrastructure and applications.

Disaster Recovery

Backup systems, recovery procedures and infrastructure redundancy.

Audit Requirements

Infrastructure changes, security events and administrative actions logged permanently.

Compliance Requirements

Support security reviews, audits and regulatory assessments.

Performance Requirements

Security controls must scale to support global traffic and millions of users.

Acceptance Criteria

All platform services remain protected, monitored and resilient against common attack vectors.